BSIDES BUDAPEST | 04. 29.

Prompts to Production: Building Effective Security Automation

12+ years in software security

Securing cool startups/scaleups globally

MSc in Data Analytics/ML for fun

CISSP, OSCP, ISO 42001, ISO 27001, ...

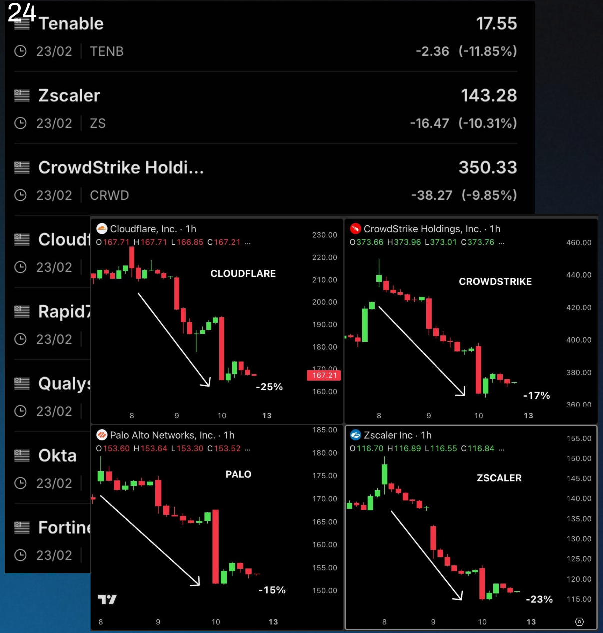
Jozsef Ottucsak (@fuzboxz)

Staff Product Security Architect
Diligent Inc.

Introduction

Where are we?

Claude Code Security Skill - 2026. February 24



Anthropic Mythos - 2026. April 11

Current Landscape

Cybersecurity is dead - agentic security is king.
At least that's what the market says.

Paradigm Shift

AI adoption can change entire way of work, velocity of changes and how we interact with stakeholders, but it's a double edged sword.

Zero to Hero

My goal is to arm you with the mindset and tools required to be successful during this transition.

Goals

Primer on AI tooling and processes

Happy paths, problems, tips and tricks

How I use AI in my work

Generative AI Evolution - I

Fundamentals

LLMs **predict text** using mathematical patterns learned from massive datasets and fine-tuning. Base models already contain large amounts of security knowledge from public resources.

Reasoning

Some models generate internal chain of thought text to come up with better outputs. These are called thinking or reasoning models. **Reasoning blocks are often hidden** from the user.

Tool Use / RAG

LLMs produce **tool call** syntax that the **host** processes and **runs**. Results are then fed back into the LLM for processing and output.

Generative AI Evolution - II

Multimodal Models

Encodes images or sound into **mathematical representation** understandable for machines. Transforms data to a **shared format** so that it can process information in multimodal content just like it text.

Computer Use

Allows an agent to interact with the **desktop**, browser sessions, etc. Can allow agent to execute workflows or troubleshoot and fix user problems.

Enterprise AI

Reduce human labor by automating manual processes. May or may not keep **human in the loop**.

Local, IaaS or API?

Data Control

Self-hosting provides complete control over data storage and access. The more abstracted the hosting solution the less control you have over how data is stored or processed.

Resource Efficiency

Self hosting infrastructure requires upfront investment, takes time and planning.
For APIs or IaaS you pay based on usage and can scale down or up.

Management and Maintenance

Self-hosting means that you have complete responsibility from planning to ops.
IaaS takes away some of the hardware management pain points and API inference simplifies this even more.

Model Support and Guardrails

For self-hosted and IaaS you are stuck with open-weight models which can be less advanced and often come from chinese origin.
With API inference you can access frontier models, but guardrails may block security tasks.

My local setup

Agent Runner

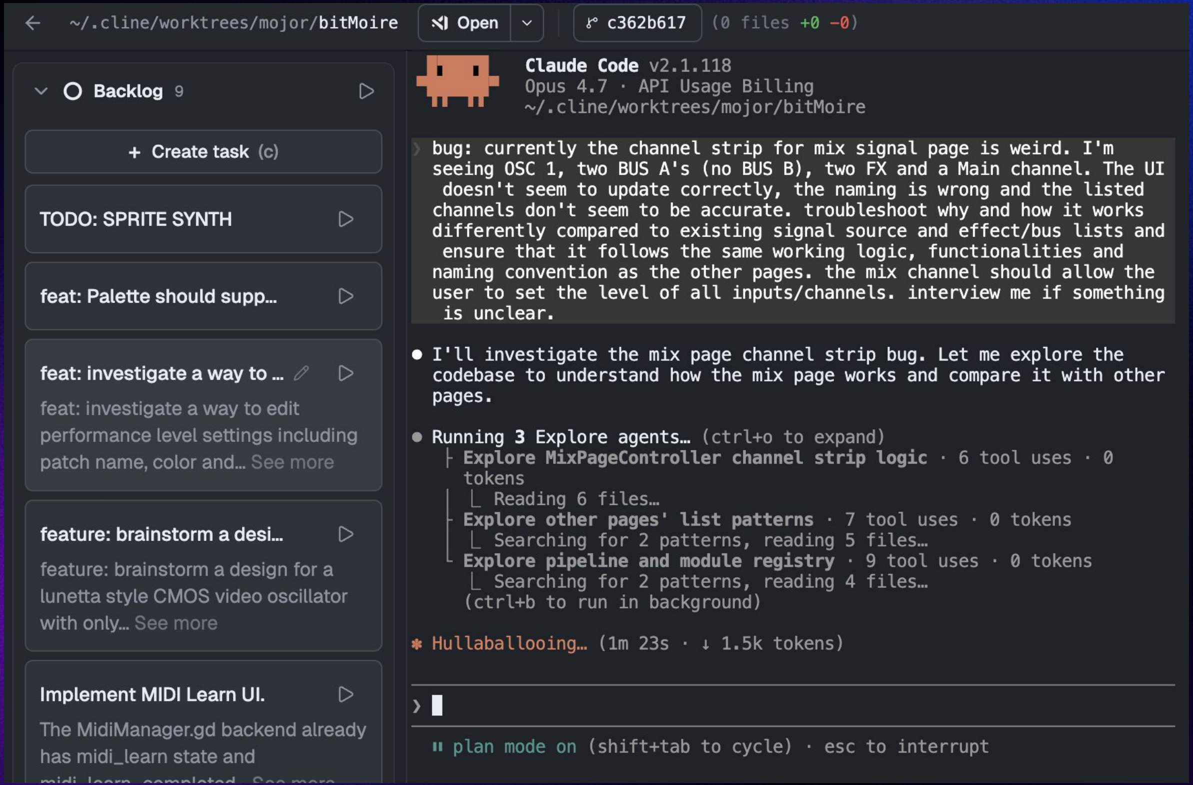
- Bazzite Linux
- Refurbished HP workstation with nvidia RTX 3060 6 GB + 32 GB RAM
- Using podman-quadlets, devcontainers, sandboxing
- Traefik rev. proxy middleware for AuthN, AuthZ, HTTPS
    - Cline Kanban running Claude Code agents
    - LiteLLM Proxy
    - Open WebUI
    - OpenClaw+Whisper (speech-to-text)

TODO: Evaluate Pi, Vibe Kanban and Hermes

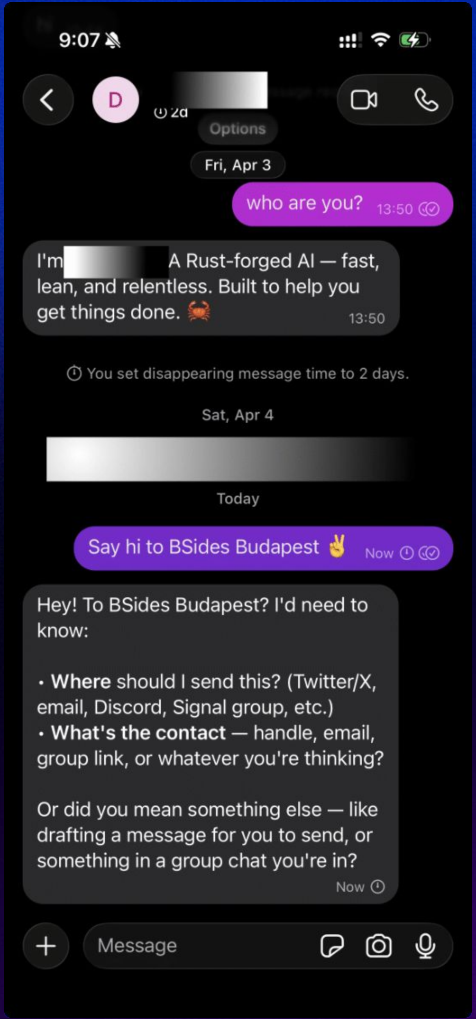
Local AI Machine

- Windows 11/Ubuntu
- Used to be a gaming PC, now it's for local inference
- Intel Core i5 12600k, nvidia RTX 3090 24 GB + 128 GB RAM
- Way too slow and limited for coding use (glm-4.5-air)
- LM Studio / Jan / Ollama
- ComfyUI

TODO: Boot into Linux and start inference server when asked by Agent Runner.



~/.cline/worktrees/mojor/bitMoire
Open
c362b617 (0 files +0 -0)
Backlog 9
+ Create task (c)
TODO: SPRITE SYNTH
feat: Palette should supp...
feat: investigate a way to ...
feat: investigate a way to edit performance level settings including patch name, color and... See more
feature: brainstorm a desi...
feature: brainstorm a design for a lunetta style CMOS video oscillator with only... See more
Implement MIDI Learn UI.
The MidiManager.gd backend already has midi_learn state and
Claude Code v2.1.118
Opus 4.7 · API Usage Billing
~/.cline/worktrees/mojor/bitMoire
bug: currently the channel strip for mix signal page is weird. I'm seeing OSC 1, two BUS A's (no BUS B), two FX and a Main channel. The UI doesn't seem to update correctly, the naming is wrong and the listed channels don't seem to be accurate. troubleshoot why and how it works differently compared to existing signal source and effect/bus lists and ensure that it follows the same working logic, functionalities and naming convention as the other pages. the mix channel should allow the user to set the level of all inputs/channels. interview me if something is unclear.
● I'll investigate the mix page channel strip bug. Let me explore the codebase to understand how the mix page works and compare it with other pages.
● Running 3 Explore agents… (ctrl+o to expand)
├ Explore MixPageController channel strip logic · 6 tool uses · 0 tokens
⎿ Reading 6 files…
├ Explore other pages' list patterns · 7 tool uses · 0 tokens
⎿ Searching for 2 patterns, reading 5 files…
└ Explore pipeline and module registry · 9 tool uses · 0 tokens
⎿ Searching for 2 patterns, reading 4 files…
(ctrl+b to run in background)
✱ Hullaballooing… (1m 23s · ↓ 1.5k tokens)
❯
⏸ plan mode on (shift+tab to cycle) · esc to interrupt



9:07
D
2d
Options
Fri, Apr 3
who are you? 13:50
I'm [redacted] A Rust-forged AI — fast, lean, and relentless. Built to help you get things done. 🦀 13:50
You set disappearing message time to 2 days.
Sat, Apr 4
Today
Say hi to BSides Budapest ✌️ Now
Hey! To BSides Budapest? I'd need to know:
• Where should I send this? (Twitter/X, email, Discord, Signal group, etc.)
• What's the contact — handle, email, group link, or whatever you're thinking?
Or did you mean something else — like drafting a message for you to send, or something in a group chat you're in?
Now
Message

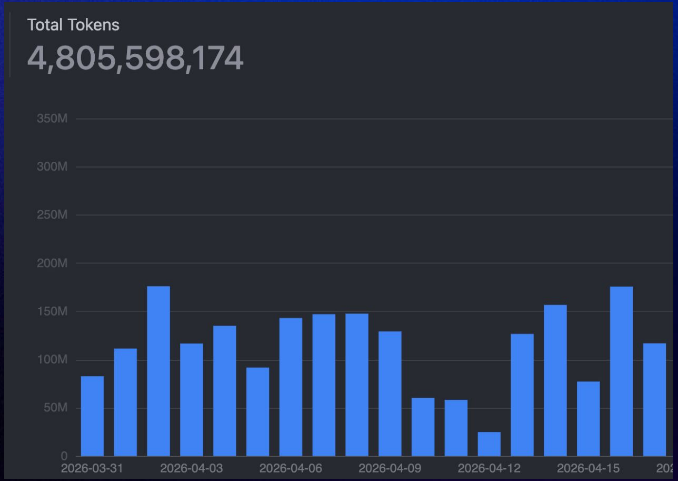
SaaS/PaaS services

Free:

- Google NotebookLM (free tier)
  - Processing and understanding documents <10
- Github Copilot (free tier) - **RIP** 💀
  - Limited chat, code completion
- Qwen Code (free tier) - **RIP** 💀
  - From 1000 to 100 requests per day
- Tavily (free tier)
  - Web search

Paid:

- Google Gemini (Pro) (~$8 per month)
  - Brainstorm, PoC scripts, reasoning
- AWS Bedrock (metered)
  - Work related, API pricing = $$$$$
- z.AI Legacy GLM Coding Plan Pro (~$11 per month) - **RIP** 💀
  - Everything related to coding (5 hour rolling window limits)
- Runpod (on-demand)
  - Renting GPUs for model training and fine-tuning



Level 1 - Chat

Directly prompting through a web interface
Useful for one-off, unstructured or ad-hoc tasks
Tool use: Web-Search, RAG from company data

Chat in my workflow

Deep dive into implementation specifics

- *"What does authentication and authorization look like for this service?"*
- *"Is this vulnerability actually exploitable?"*
- *"What compensating controls exist within this codebase?"*

Create shell one liners or scripts for non-repeatable tasks

- *"Give me a command to delete all files that are under x megabyte and convert them to this format using ffmpeg"*
- *"Give me a command that replaces xyz within the files with abc instead"*

Look for documents, Jira tickets, Confluence pages, etc within company spaces

- "Find out why an architecture decision was taken, look for tickets, emails or documents as evidence"
- "Find all copied references to this policy that I want to update"

Level 2a - Documented Prompts

Standardized prompts for repeated tasks
Re-usable, possibly version controlled
Can be called from web interface, agentic CLI or IDE
Useful where tasks are often repeated, consistency is required or prompts are shared between multiple people
Previously called custom prompts and slash commands within agentic CLI/IDEs

Security Examples:

- Research, review and document third-party library
- Rule generation for SIEM or SAST
- Create formal incident response document from notes

Alternative to Prompts

Migrated to agent skills
When something is a repeated task

- Create a skill
- Write a script
- Create just command
- Create container/quadlet

Level 2b - Hooks

Hooks provide a way to run deterministic tasks during interactions with AI tooling
Communication via exit code or JSON
Saves context and enforces specific checks without relying on agent execution
Run automatically before or after certain events trigger related to agents, tools, session or tasks
Security Examples:

- Load environment variables during session start
- Run end-to-end tests on code generation
- Verify that generated rule/signature is valid
- Clean up temporary files after execution
- Nuke and turn off sandbox when analysis is done

How I use hooks

Mostly in ops and dev projects
Makes it harder for the LLM to turn projects into unmaintainable slop
Deterministic automation and code convention enforcement saves tokens
Only output during failure or when no coding agent is used
I mostly use git pre-commit hooks, because Claude hooks are fragile

Claude hooks:

- *Filter, simplify and sanitize inputs*
- *Disallow reading secrets, env vars*

Git hooks:

- *Formatter, linter, security scans*
- *Run automated tests*
- *Compile and launch binary in worktree*
- *Rebuild knowledge base graph based on changes*

Level 2c - Skills

Replaced prompts
Skills are now the "standardized" way of sharing capabilities
Only thing required is SKILL.md
Can include scripts, references (documentation) and assets (static resources)
https://agentskills.io

How I use skills

Few carefully vetted skills (superpowers-optimized, graphify, rtk)
Most published skills are unreviewed AI generated slop
Long generic instructions focusing on the wrong things
Often tells the model things that it already "knows"
Not optimized for token efficiency

Just build your own 👷🏻

Level 3 - Subagents

Orchestrator agent can delegate tasks to subagents
Subagents have isolated context and can run in parallel
Gets called with minimal inputs, executes work and returns results
Access can be limited to only a subset of tools
Exists within agentic IDE/CLI and in recent web interfaces
Not supported in Skills, but you can call a skill from subagent

How I use subagents

I use subagents for **everything** except for simple bug fixes
Multi-phase, long running tasks, exploration, etc.
Invoke them with magic incantation: "use subagents"

Reverse Engineering ARM Binaries

Hardware synthesizers and effects are expensive and take up a huge space
What if we could understand DSP using software updates?

My fun little hobby project for hardware synthesizers that I want to understand

Process:

Plan

Sub-Agents:

- Download firmware and reverse engineer using CLI tools
- Document signal flow, DSP, magic numbers, parameter ranges, filter coefficients
- Based on documentation implement using SuperCollider or Javascript

Verify that implementation is accurate and fix issues

Repeat 2-3 times until implementation is correct

Firmware Analysis: Beads & Clouds Granular Synthesis Modules

WAV File Specifications

Beads Firmware (beads.wav)

Clouds Firmware (clouds_1.31.wav)

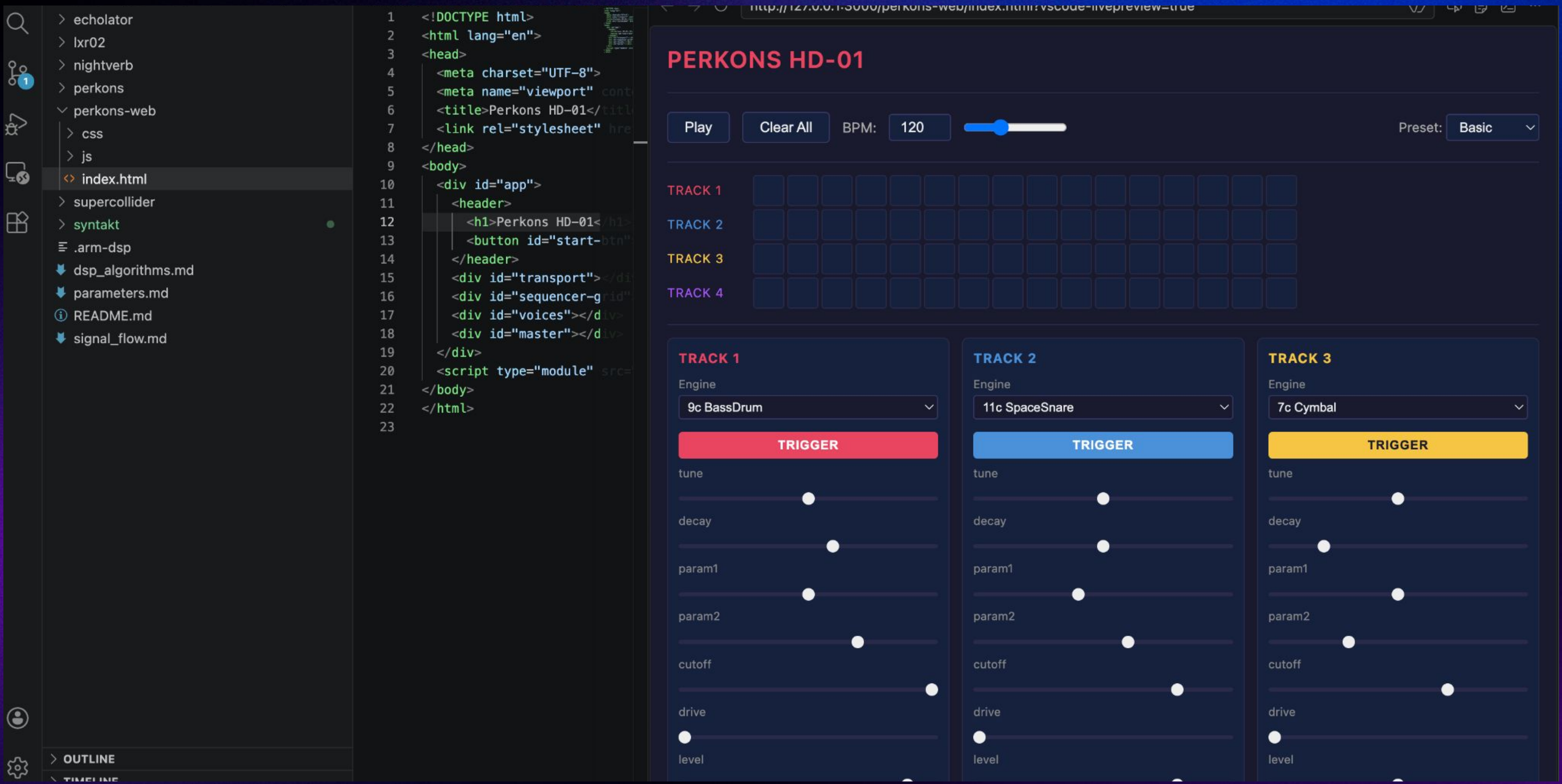
Property	Value
Duration	123.98 seconds
Data Size	11,902,464 bytes
Samples	5,951,232
File Size	~11.9 MB

Encoding Scheme

QPSK Modulation (Correct Method)

The firmware is encoded using **QPSK (Quadrature Phase Shift Keying)** modulation at 6000 Hz carrier:

- **I channel** (in-phase): $\cos(2\pi ft)$
- **Q channel** (quadrature): $\sin(2\pi ft)$
- **4 phases**: 45°, 135°, 225°, 315° (encoding 2 bits per symbol)
- **Symbol rate**: 6000 symbols/second
- **Data rate**: 12000 bps (2 bits per symbol)


echolator
lxr02
nightverb
perkons
perkons-web
css
js
index.html
supercollider
syntakt
.arm-dsp
dsp_algorithms.md
parameters.md
README.md
signal_flow.md
OUTLINE
<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="UTF-8">
<meta name="viewport"
<title>Perkons HD-01</
<link rel="stylesheet"
</head>
<body>
<div id="app">
<header>
<h1>Perkons HD-01<
<button id="start-
</header>
<div id="transport">
<div id="sequencer-g
<div id="voices"></d
<div id="master"></d
</div>
<script type="module"
</body>
</html>
PERKONS HD-01
Play
Clear All
BPM:
120
Preset:
Basic
TRACK 1
TRACK 2
TRACK 3
TRACK 4
TRACK 1
Engine
9c BassDrum
TRIGGER
TRACK 2
Engine
11c SpaceSnare
TRIGGER
TRACK 3
Engine
7c Cymbal
TRIGGER
tune
decay
param1
param2
cutoff
drive
level

Level 4 - Agentic Frameworks

For highly structured repeated tasks that still need to handle ambiguity
Cross-organization skills shared with other teams
Everything defined on UI or in code with agent instructions in prompts
Frameworks offer much higher control at the cost of complexity
Features, complexity and cloud provider support differs across frameworks

Security Examples:

- Any automation running programmatically
- Create SAST rule from finding for opengrep/semgrep
- Security reviews on third party components
- Generate AI System Risk and Impact Assessments

```
# Semgrep Mobile Security Ruleset

A comprehensive collection of Semgrep rules for detecting security vulnerabilities in mobile applications (Android and iOS), aligned with OWASP Mobile Application Security (MAS) standards.

## Overview

This ruleset provides static analysis capabilities for identifying security vulnerabilities in mobile applications built for:
- **Android**: Java and Kotlin
- **iOS**: Swift and Objective-C

The rules are mapped to:
- **OWASP MASVS** (Mobile Application Security Verification Standard)
- **OWASP MASTG** (Mobile Application Security Testing Guide)
- **OWASP MASWE** (Mobile Application Security Weaknesses)
- **CWE** (Common Weakness Enumeration)

## Project Structure

```
semgrep-mobile/
├── rules/
│   ├── android/   # Android-specific rules (Java/Kotlin)
│   ├── ios/   # iOS-specific rules (Swift/Objective-C)
│   └── tests/   # Test cases and validation results
├── docs/   # Documentation and mappings
└── scripts/   # Validation and testing scripts
```
```

```
===========================================
FINAL VERIFICATION - ALL 28 RULES
===========================================

Rule Count:
  Android Java: 119
  iOS Swift: 103
  Android Kotlin: 3
  TOTAL: 225

Verification Test - Detecting Hardcoded Encryption Key:
----------------------------------------------------------
│ 1 Code Finding │

✅ SUCCESS! All 28 rules are working and detecting vulnerabilities!

See full report: docs/FINAL_TEST_REPORT.md
```

[1] Dashboard [2] Updates [3] Security [4] Providers [5] Hardening [6] Packages [7] Services [8] Resources [9] Fi

Overseer Dashboard

OK system Bazzite 43.20260420.0 (Kinoi	OK bazzite Bazzite system — 106 ujust r	OK flatpak 12 apps/runtimes installed,	OK homebrew 151 formulae/casks installed
OK npm 2 projects scanned, 61 outda 61 updates 9 alerts	OK podman 0 containers (0 running, 0 s	OK resources CPU 0.5% | RAM 16.8% | GPU 1	OK services 257 services (82 active, 23 23 alerts

P:8 | U:61 | A:32 | [r] refresh [q] quit

Agentic Automation

Given unlimited funds, you can probably fix a lot of problems using AI automation
Using agents instead of deterministic tools causes much higher operating costs
Just because you can do it, does not mean that you should
If possible use batch inference and prompt caches to save $$$
Consider entire cost of a process not just the automated part

Cheap:

- Writing code, tests, automation
- Making decision based on ambiguous but clean data
- Where humans cannot scale **AND** there is ROI

Expensive:

- Anything done at scale
- Direct processing of data using an LLM
- Using generic thinking frontier models (nobody got fired for using Sonnet 🤷)
- Flaky, ambiguous, non-linear execution workflows

VRackConverter

Convert patches between VCV Rack 2, MiRack, VCV Rack v0.6, and Cardinal formats

INPUT PATCH

Drop your patch file here
or click to browse

Supports: .vcv (V2, V0.6, Cardinal), .mrk directories, .zip (containing .mrk folder)

Works entirely in your browser. No data is sent to any server.


Patch 1 - Untitled Performance
bitMoire
Perform
Patch
FX
Mix
Mod Matrix
Settings
Play
Stop
120.0 BPM
1:1
00:00:00.00
Sources
+
OSC A
OSC A
Preview
PARAM_NOISE_TYPE
Speed
Scale
Tiling X
Tiling Y
Simplex
MACROS
M1
M2
M3
M4
M5
M6
MODULATORS
1
2
3
4
5
6
7
8
Type Sine
Sync
Hz
Speed
1.00 Hz
Phase
0.00

Questions?

Thank you!